

Computer Security

CoSc4012_

June 15, 2025

Compiled by: Natan Asrat

https://www.linkedin.com/in/natan_asrat

Computer Security

- Security: the quality or state of being secure (to be free from danger)
 - protection against adversaries
 - National security: protects the sovereignty of a state, its assets, its resources, and its people

Computer Security

- Information Assurance: assuring information and managing risks related to the use, processing, storage, and transmission of information or data, the systems and processes used for those purposes.
 - protection of the integrity, availability, authenticity, non-repudiation and confidentiality of user data.
 - physical, technical and administrative controls to accomplish these tasks, not only digital
 - restoration of information systems by incorporating protection, detection, and reaction capabilities.
 - superset of information security.

Computer Security

- Information Assurance – Pillars:

- Confidentiality:

- Preserving authorized restrictions on access and disclosure.
 - Includes personal privacy and proprietary information protection.

- Integrity:

- protecting against improper information modification or damage

- Availability:

- ensuring timely and reliable access to and use of information.
 - service isn't denied to authorize users.

Computer Security

- Information Assurance – Pillars:
 - Authentication:
 - that you are who you say you are.
 - non-repudiation:
 - Prevention of either the sender or receiver denying a transmitted message.
 - Prove the occurrence of a claimed event or action and its originating entities.

Computer Security

- Information Assurance:
 - Information Assurance strategy
 - Cyber security awareness and education
 - Strong cryptography
 - Good security-enabled commercial information technology
 - An enabling global Security Management Infrastructure; and
 - A civil defense infrastructure equipped with an attack sensing and warning capability and coordinated response mechanism

Computer Security

- InfoSec, computer security & IA
 - IA: measures that ensure availability, integrity, authentication, confidentiality, and non-repudiation.
 - Computer Security: (W. Stallings): protection to an automated information system

Computer Security

- InfoSec, computer security & IA
 - InfoSec (Information protection) : protection from unauthorized access, use, disclosure, disruption, modification, perusal, inspection, recording or destruction.
 - Aspects:
 - IT security
 - IA: ensuring that data is not lost when critical issues like natural disasters, system malfunction, physical theft, etc. arise

Computer Security

- Enterprise security & Cyber defense
 - Enterprise security: building systems to remain dependable in the face of malice, error, or mischance.
 - Cyber defense: includes response to actions and critical infrastructure protection and IA for possible networks.
 - Business-driven approach to enterprise security: enabling the objective of an organization by controlling operational risk.

Computer Security

- Threats, vulnerabilities, risk, controls (W. Stallings)
 - Adversary (threat agent): entity that attacks (threat) a system, e.g. all hackers in the world
 - Threat: events that can potentially harm an information system
 - Vulnerability: weaknesses or fault in an information system or its components.
 - Attack: actual violation of security that derives from an intelligent threat

Computer Security

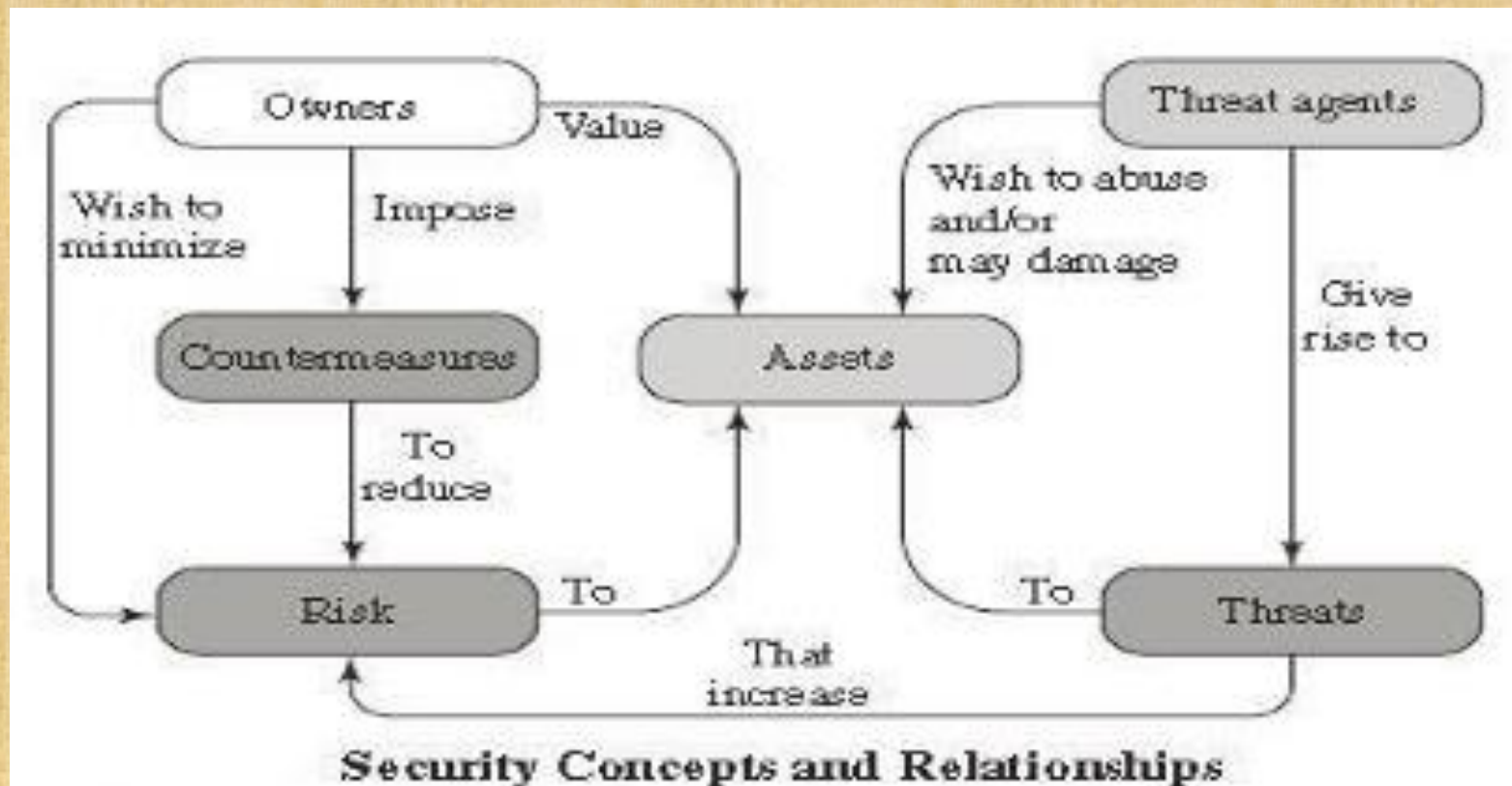
- Threats, vulnerabilities, risk, controls (W. Stallings)
 - Risk: expectation of loss (exploitation a particular vulnerability)
 - Risk = Threats x Vulnerabilities
 - Control, safeguard, or countermeasure: An action, device, procedure, or technique that reduces a threat, a vulnerability, or an attack by eliminating or preventing it, by minimizing the harm it can cause, or by discovering and reporting it so that corrective action can be taken.

Computer Security

- Threats, vulnerabilities, risk, controls (W. Stallings)
 - Security Policy: set of rules and practices regulating how a system/organization protects sensitive and critical system resources.
 - System Resource (Asset):
 - Data contained in a system; or
 - a service provided by a system; or
 - a system performance; or
 - an item of system equipment (hardware, software, or documentation); or
 - a facility that houses system operations and equipment.

Computer Security

- Information security models and mechanisms
 - Model for Computer Security



Computer Security

- Information security models and mechanisms
 - Goals of computer security
 - Confidentiality
 - Integrity
 - Availability... (same as above)
 - Security Attack
 - Active attack: attempt to alter/affect system resources or their operation
 - Passive attack: an attempt to learn/make use of information from the system that does not affect system resources
 - Inside attack: Initiated by an entity inside the security perimeter (an insider).
 - Outside attack: Initiated from outside the perimeter.

Computer Security

- Information security models and mechanisms
 - Types of Attacks on Data CIA
 - Disclosure/Interception (Attack on data confidentiality): unauthorized party snooping, or getting access to a resource
 - Modification/Deception (Attack on data integrity): unauthorized party modifying a resource,
 - Disruption/Interruption (Attack on data availability): unavailable services/resources, DoS
 - Fabrication: unauthorized party inserts a fake asset/resource, loss of confidentiality, authenticity and integrity of the message

Computer Security

- Information security models and mechanisms
 - Types of Attackers
 - Amateurs: Opportunistic attackers (use a password they found), Script kiddies
 - Hackers - non-malicious
 - Crackers - malicious
 - Career criminals
 - State-supported spies and information warriors

Computer Security

- Information security models and mechanisms
 - Countermeasure Methods to Risk
 - Prevent attack: Block attack / Close vulnerability
 - Deter attack: discourage potential attackers, Make attack harder,
 - Deflect attack: Make another target more attractive than this target
 - Detect attack: accept that an attack will occur; determine that an attack is under way, or has occurred, and report it.
 - Recover from attack: Stop attack, assess and repair damage or restore the operations of the business

Computer Security

- Information security models and mechanisms
 - Controls: Security policies & mechanisms
 - Encryption: primary control
 - Software controls: password checker, virus scanner, IDS (intrusion detection system)
 - Hardware controls: Locks, Smart cards, dongles, hardware keys...
 - Policies and procedures: users' legal and ethical standards; eg. password policy
 - Physical controls:
 - natural and man-made disaster protection;
 - walls, locks, guards, security, cameras, backup copies and archives

Computer Security

- Information security models and mechanisms
 - Principles of Computer Security
 - Principle of Easiest Penetration
 - Principle of Adequate Protection
 - Principle of Effectiveness: Controls must be efficient, easy to use, and appropriate.
 - Principle of Weakest Link: Security can be no stronger than its weakest link.
 - Principles of Least Privilege: Don't give more privileges than necessary for the job.
 - Defense in Depth: having more than one layer or type of defense

Computer Security

- Information security models and mechanisms
 - Principles of Computer Security
 - Minimization: do not run any software, or applications that aren't required for the job
 - Compartmentalization: limits the damage in other compartments when one compartment is compromised.
 - Keep Things Simple: Complexity is the worst enemy of security.
 - Fail Securely: if security measure has failed, the system is not rendered to an insecure.
 - Balancing Security and Access

Computer Security

- Computer Threats/Attacks

- Types of Threats/Attacks

- Physical Attack: Stealing, breaking or damaging of computing devices
 - Malware Attack: A generic term for software that has malicious purpose.
 - Viruses
 - Worms
 - Trojan horses
 - Spy-wares
 - Zombie
 - Botnets
 - Bacterium
 - Spam/scam, identity theft, e-payment frauds, etc.
 - Logic bomb
 - Backdoor (Trapdoor)
 - Adware
 - Flooders (DoS client)
 - Key loggers
 - Rootkit

Computer Security

- Computer Threats/Attacks

- Types of Threats/Attacks

- Hacking /Intrusion/: attempt to intrude or gain unauthorized access, purpose may or may not be for malicious purposes.
 - Cracking: is hacking conducted for malicious purposes.
 - Denial of Service (DoS) Attack: Blocking access from legitimate users
 - Distributed DoS Attack: tricking routers into attacking a target or using Zombie hosts to simultaneously attack a given target with large number of packets.
 - Spoofing: MAC cloning, IP spoofing, and email spoofing
 - Password attacks: guessing password; social engineering attack, Dictionary attack

Computer Security

- Computer Threats/Attacks

- Types of Threats/Attacks

- Cryptographic Attack:

- Frequency Analysis attack: Guess values based on frequency of occurrence
 - Brute-force attack: attacker tries every possible key on a piece of ciphertext.
 - Cryptanalysis: the process of breaking an encrypted code.
 - Ciphertext only Attack,
 - Known plaintext Attack,
 - Chosen plaintext Attack,
 - Chosen ciphertext Attack, and
 - Chosen text Attack

Computer Security

- Computer Threats/Attacks

- Class of Attacks:

- Reconnaissance:

- hackers first identifies a target to launch an attack,
 - extract maximum information regarding this target,
 - understand its vulnerabilities,
 - and then only explore the best ways to exploit it.

- Examples:

- Credential Theft using Keyloggers and Spyware; Identity
 - Theft using spam e-mail, phishing attack and social engineering attack

Computer Security

- Computer Threats/Attacks

- Class of Attacks:

- Access: Once the attacker Reconnaissance the target, S/he starts a successful exploitation and continued access to the system. Then, the attacker is in control of the target.
 - Denial of Service: Once the attacker having a successful access to the system. S/he starts to deny users from accessing or using the service or system.

Computer Security

- **Application of Security Mechanisms**

- Terms:

- Plaintext - the original form of a message
 - Ciphertext - the coded/encrypted form of a message
 - Cipher - an encryption method encompassing the algorithm and key
 - Key - known only by the sender/receiver, value that the cipher, as an algorithm, operates on.

Computer Security

• **Application of Security Mechanisms**

- Terms – Key:

- Symmetric: same key used for encryption & decryption

- Key Distribution: requires both parties to share a common secret key

- Key Hierarchy:

- Session key: temporary key, for one logical session then discarded

- Master key: used to encrypt session keys, shared by user & key distribution center

- Advantage: Simpler and faster

- Disadvantages: Less secured, key exchange problem, large number of keys are needed

Computer Security

- **Application of Security Mechanisms**

- Terms – Key:

- Symmetric – Categories of symmetric ciphers:

- Stream Ciphers: one bit or one byte at a time
 - Block Ciphers: characters of a fixed size (a block) encrypted at once
 - Playfair,
 - Hill ciphers,
 - modern symmetric ciphers
 - Combination Cipher

Computer Security

- **Application of Security Mechanisms**

- Terms – Key:

- Symmetric – Examples:

- Data Encryption Standard (DES) (56bits key)
 - 64 bit block length

Computer Security

• **Application of Security Mechanisms**

- Terms – Key:

- Symmetric – Examples:

- Data Encryption Standard (DES) (56bits key)

- Feistel cipher:

- half of the data block is used to modify the other half of the data block
 - then the halves are swapped.
 - passes through an initial permutation (IP) that rearranges the bits to produce the permuted input.
 - followed by sixteen rounds of the same function: permutation and substitution functions.
 - The left and right halves of the output are swapped to produce the preoutput.
 - The preoutput passed through the inverse of the initial permutation function (IP⁻¹)

Computer Security

- **Application of Security Mechanisms**

- Terms – Key:

- Symmetric – Examples:

- Triple DES (3DES) (168 bits key)
 - Advanced Encryption Standard (AES)
 - not a Feistel structure
 - one permutation and three substitution
 - Substitute bytes: S-box to perform a byte-by-byte substitution of the block
 - ShiftRows: A simple permutation
 - MixColumns: A substitution that makes use of arithmetic over $GF(2^8)$
 - AddRoundKey: A simple bitwise XOR of the current block with a portion of the expanded key

Computer Security

• **Application of Security Mechanisms**

- Terms – Key:

- Asymmetric: different keys are used for encryption & decryption

- Secret transmission of key for decryption is not required
 - Every entity can generate a key pair and release its public key
 - Breaking these algorithms
 - does not involve trying every possible key;
 - involves trying to factor the large number (or taking discrete logarithms in a very large finite field)
 - If the number is too small, you have no security. If number is large enough, secured against all computing power.
 - Advantages: more secured, Authentication
 - Disadvantages: relatively complex

Computer Security

- **Application of Security Mechanisms**

- Terms – Key:

- Asymmetric – Public Key Infrastructure (PKI):

- consists of

- Certification Authorities (CAs),
 - Registration Authorities (RAs),
 - Certificate holders,
 - Clients,
 - Repositories,
 - Cryptographic Algorithms and Protocols.

- management of public key and distribution of digital certificates

- SSL certificates and TLS (newer version)

- HTTPS certificates serve to identify the web site; ensure no-one can eavesdrop

Computer Security

• **Application of Security Mechanisms**

- Terms – Key:

- Asymmetric – Examples:

- El Gamal: developed by Taher ElGamal

- Variable key size (512 or 1024 bits), Less common than others

- Diffie-Hellman Key Agreement (DH)

- first practical method for secret share over unsecured channel

- Rivest, Shamir, Adleman (RSA)

- Variable Key Size (512, 1024, or 2048 bits), Most popular public key algorithm
 - Principle: no mathematical method to efficiently find the prime factors of large numbers
 - private and public keys are constructed from very large prime numbers

Computer Security

- **Application of Security Mechanisms**

- Digital Signature Algorithm (DSA)
 - Digital Signature procedure:
 - authenticates sender, does not give privacy of data
 - Sender encrypts message with its private key
 - Receiver can decrypt using sender's public key
 - Encipher (encrypt): converting plaintext to ciphertext
 - Decipher (decrypt) - recovering plaintext from ciphertext
- Hash functions
 - hash function takes a variable-size message as input and produces a fixed-size output (hash code)
 - no key is used
 - impossible for the contents of the plain text to be recovered
 - used by many operating systems to encrypt passwords

Computer Security

- **Application of Security Mechanisms**

- Cryptography Classification - Classical/Conventional Cryptography:
 - Substitution Cipher: replaces one symbol with another
 - Monoalphabetic Ciphers: one-to-one relationship between symbols in cipher and plain text
 - Additive cypher
 - Multiplicative cypher (with modulo)
 - Affine Ciphers: uses a pair of keys
 - Polyalphabetic Ciphers: one-to-many relationship between a character in the plaintext to a character in the ciphertext
 - Autokey Cipher
 - Playfair Cipher
 - Vigenere Cipher
 - Hill Cipher: key matrix with multiplicative inverse

Computer Security

- **Application of Security Mechanisms**

- Cryptography Classification - Classical/Conventional Cryptography:

- Transposition Cipher: changes the location of the symbols

- Keyless Transposition Ciphers: permute the characters

- rail-fence transposition: transposed into several rows

- Example (2 rail/row $\rightarrow$ key = 2)

- Plaintext: THEBIGBANGTHEORY

- Output:

- THEBIGBA NGTHEORY

- columnar transposition: transposed into several columns

- Example (2 columns $\rightarrow$ key = 2)

- Plaintext: SECRET

- Output

- E E

- C T

Computer Security

- **Application of Security Mechanisms**

- Cryptography Classification - Classical/Conventional Cryptography:
 - Transposition Cipher: changes the location of the symbols
 - Keyed Transposition Ciphers: divide the plaintext into groups of predetermined size, called blocks, and then use a key to permute the characters in each block separately
 - Permutation key: key used for encryption and decryption
 - Combining the Two Approaches

Computer Security

- **Application of Security Mechanisms**

- Cryptography Classification:

- Modern Cryptography: Symmetric key cryptography and Public key cryptography
 - Based on Kerckhoff's principle, always assume they, know the encryption algorithm.
 - Resistance of the cipher to attack must be based only on the secrecy of the key and the strength of the algorithm.

Computer Security

- **Application Security**

- Vulnerability: any mistakes or weakness in the system security
 - Vulnerability Assessment: a software testing technique to evaluate the sudden increase of risks
 - Penetration Testing: authorized simulated attack on a computer system performed to evaluate the security of the system

Computer Security

- **Application Security**

- Vulnerability:

- Types of vulnerability scanner:

- Host Based:

- Identifies the issues in the host or the system.
 - carried out by using host-based scanners

- Network Based:

- will detect the open port, and identify the unknown services running on these ports.
 - carried out by using Network-based Scanners.

- Database Based :

- identify the security exposure in the database systems to prevent from SQL Injections.

Computer Security

- **Application Security**

- Vulnerability - Testing Methods:

- Active Testing: tester will actively involve in the process of finding out the new test cases and analyzes the results.
 - Passive Testing: monitoring the result of running SW under test without introducing new test cases or data.
 - Network Testing: measuring the state of network operation over a period of time to find out the problems created by new services.
 - Distributed Testing: applied for testing distributed applications.
 - Penetration Test (pen test):
 - To identify both weaknesses (vulnerabilities) & strengths, to enable a full risk assessment.
 - Determine whether a system is vulnerable.
 - Determine whether defenses were sufficient.

Computer Security

- **Application Security**

- Vulnerability:

- Secure Shell (SSH)

- cryptographic protocol for operating NW services securely over an unsecured NW

- Secure Email

- adds confidentiality and integrity protection to ordinary e-mail
 - example: PGB

- Secure Web servers

- securing the website or web application itself and the network around it.
 - i.e. securing against Cross-Site Scripting (XSS)

Computer Security

- **Firewall**

- program or network devices (e.g. router) which filters access to a protected network from the internet connection
- monitors & controls incoming & outgoing network traffic based on predetermined security rules.

Computer Security

- **Firewall**

- Categorizes:

- Network firewalls: traffic b/n two or more networks and run-on NW hardware.
 - Implemented at a specific point in the network path and protects all computers on the internal side of the firewall from all computers on the external side of the fire wall.
 - Host-based firewalls: run on host computers and control network traffic in/out of those machines.
 - Packet Filtering Router: Examines TCP/IP header information of network data packets going in both directions.

Computer Security

- **Firewall**

- Categorizes:

- Application-Level Gateway (application firewall / proxy server): runs special software that acts as a proxy for a service request.
 - Proxy server receives requests for Web pages, accesses the Web server on behalf of the external client, and returns the requested pages to the users.
 - Circuit Level Gateway: Standalone Software that sets up two TCP connections (inside & outside). It determines which connections will be allowed.

Computer Security

- **Firewall**

- Firewalls implementation
 - Hardware firewalls: a stand-alone product or integrated into the router.
 - Software firewalls: installed on your computer and will protect your computer from outside
 - Combination of both

Computer Security

- Physical security
 - nothing else about a computer system can be called secure without physical security

Computer Security

- Operations security
 - weaknesses in an operating system are the most valued amongst crackers.
 - Biometric (e.g. voice, face, retina, iris, fingerprint) and physical token-based (swipe cards, pin- generating cards) authentication are sometimes used to augment simple passwords, but the costs and accuracy of the technology limit their adoption.

Computer Security

- Access control
 - many systems define which packets may and which packets may not pass based on the sender's IP address (router access control lists)
 - access enforcement mechanism:
 - authorizes requests from multiple subjects (e.g. users, processes, etc.)
 - to perform operations (e.g., read, write, etc.)
 - on objects (e.g., files, sockets, etc.).

Computer Security

- Access control
 - Network access control (NAC): managing access to a network.
 - NAC authenticates users logging into the network
 - determines what data they can access and actions they can perform
 - examines the health of the user's computer or mobile device (the endpoints).
 - operating system provides an access enforcement mechanism.
 - Concepts of access control:
 - a protection system that defines the access control specification and
 - a reference monitor that is the system's access enforcement mechanism that enforces this specification.

Computer Security

- Plan, Design and manage security, security policies, business continuity plans, disaster recovery plans, and social and legal issues of information security
- Design secure systems for real world information system services